

# Reto Profesional Tema 5

## Informe de Ciberseguridad

Implementación de THD en el Sector Turístico

*Cliente: +hotel*

Jimenez Alonso Javier · Serrano Membrive Julio

---

## 1. Introducción

En la última década, la digitalización del sector hotelero ha sido intensa: reservas online, check-in digital, sistemas de gestión centralizados y dispositivos conectados en habitaciones son ya la norma. Esta transformación ha traído eficiencia, pero también ha abierto la puerta a amenazas que antes simplemente no existían.

Los tipos de ciberataques más frecuentes que hemos detectado en el sector son el ransomware, que cifra los sistemas de gestión y paraliza la operativa del hotel; el robo de datos de clientes a través de brechas en bases de datos; el phishing dirigido al personal de recepción y administración; y los ataques a dispositivos IoT como cerraduras electrónicas o sistemas de climatización. El incidente reciente sufrido por +hotel encaja en este patrón, y este informe tiene por objeto analizar los riesgos concretos y proponer soluciones.

## 2. Análisis de Riesgos de Ciberseguridad en THD Hoteleras

A continuación se presenta una tabla resumen con los tres principales riesgos identificados, sus consecuencias y las estrategias de mitigación propuestas:

| Riesgo THD                           | Descripción                                                                                                                                                                                     | Consecuencias                                                                                                                                     | Mitigación                                                                                                                            |
|--------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------|
| Ransomware / Cifrado de sistemas     | Los sistemas de reservas y PMS de +hotel son objetivos prioritarios. Un ataque cifra todos los datos operativos y exige un rescate para recuperarlos, dejando al hotel sin capacidad de operar. | Parálisis operativa total, pérdida de datos de clientes, daño reputacional y coste económico elevado por tiempo de inactividad y posible rescate. | Copias de seguridad offline periódicas, plan de continuidad de negocio (BCP) y segmentación de red.                                   |
| Vulnerabilidades en dispositivos IoT | Cerraduras inteligentes, termostatos y televisores conectados de +hotel forman una red amplia con firmware frecuentemente desactualizado y contraseñas de fábrica sin cambiar.                  | Acceso físico no autorizado a habitaciones, espionaje de huéspedes y puerta de entrada a la red corporativa del hotel.                            | Actualización automática de firmware, red IoT aislada (VLAN independiente) y monitorización continua de dispositivos.                 |
| Phishing y robo de credenciales      | El personal de recepción y reservas de +hotel recibe a diario correos de proveedores y plataformas. Los atacantes suplantan estas comunicaciones para robar credenciales de acceso al sistema.  | Acceso ilegítimo al PMS, fuga de datos de tarjetas de crédito y datos personales de huéspedes registrados en +hotel.                              | Formación continua al personal, filtros antiphishing en el correo corporativo y autenticación multifactor (MFA) en todos los accesos. |

### 2.1. Ransomware y cifrado de sistemas

El ransomware es actualmente la amenaza más destructiva para el sector hotelero. Estos ataques cifran todos los archivos del sistema y exigen un pago a cambio de la clave de descifrado. En el caso de +hotel, la parálisis de sistemas durante varios días confirma que la empresa fue víctima de un ataque de este tipo o similar.

Los sistemas de reservas, el PMS y los TPV (terminales de punto de venta) son los objetivos prioritarios, ya que su caída implica la incapacidad de operar: los empleados no pueden hacer check-in, no ven las reservas y no pueden cobrar a los clientes. El coste económico es doble: el rescate (si se paga) y los ingresos perdidos durante la inactividad.

## **2.2. Vulnerabilidades en dispositivos IoT (OT)**

La proliferación de dispositivos IoT en los hoteles modernos ha creado una superficie de ataque enormemente ampliada. Cada cerradura inteligente, termostato o televisor conectado es un potencial punto de entrada a la red corporativa si no está correctamente asegurado.

El problema principal es que estos dispositivos suelen tener firmware desactualizado, contraseñas de fábrica sin cambiar y escasas capacidades de cifrado. Un atacante que acceda a la red IoT puede, desde abrir una habitación de forma remota hasta pivotear hacia la red corporativa y acceder a bases de datos de clientes.

## **2.3. Phishing y robo de credenciales del personal**

El personal de recepción, reservas y administración maneja a diario correos electrónicos de proveedores, plataformas de distribución (Booking.com, Expedia, Airbnb) y clientes. Los atacantes suplantan estas comunicaciones para engañar al empleado y que introduzca sus credenciales en una web fraudulenta.

Con las credenciales robadas, el atacante obtiene acceso legítimo al sistema de gestión del hotel, pudiendo extraer datos de tarjetas de crédito, modificar reservas, realizar cargos fraudulentos o simplemente desplazarse lateralmente por la red para preparar un ataque mayor.

### 3. Casos Reales de Ciberdelincuencia en el Sector Turístico

Para fundamentar el análisis, se presentan a continuación tres fichas con incidentes reales documentados que ilustran los riesgos descritos:

#### Caso 1:

|                       |                                                                                                                                                                                                                                                                                                   |
|-----------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Titular               | Marriott International sufre una megafiltración de datos de 500 millones de huéspedes (2018)                                                                                                                                                                                                      |
| Enlace                | <a href="https://www.bbc.com/news/business-46401890">https://www.bbc.com/news/business-46401890</a>                                                                                                                                                                                               |
| Resumen de la noticia | Marriott reveló que su base de datos de reservas Starwood fue comprometida desde 2014. Los atacantes accedieron a nombres, direcciones, números de pasaporte, fechas de nacimiento y datos de pago de aproximadamente 500 millones de clientes. La brecha pasó desapercibida durante cuatro años. |
| Riesgos asociados     | <ul style="list-style-type: none"><li>• Almacenamiento de datos sensibles sin cifrado adecuado</li><li>• Falta de segmentación de red tras la adquisición de Starwood (2016)</li><li>• Ausencia de sistemas de detección de intrusiones (IDS) efectivos</li></ul>                                 |
| Propuestas            | <ul style="list-style-type: none"><li>• Cifrado de datos en reposo (especialmente pasaportes y datos financieros)</li><li>• Auditorías de seguridad inmediatas en adquisiciones corporativas</li><li>• Implementación de SIEM para detección temprana de anomalías</li></ul>                      |

#### Caso 2:

|                       |                                                                                                                                                                                                                                                                                                                                                            |
|-----------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Titular               | MGM Resorts paralizado por ataque ransomware: 100 millones de dólares en pérdidas (2023)                                                                                                                                                                                                                                                                   |
| Enlace                | <a href="https://www.reuters.com/technology/mgm-resorts-faces-100-million-hit-cyberattack-2023-10-05/">https://www.reuters.com/technology/mgm-resorts-faces-100-million-hit-cyberattack-2023-10-05/</a>                                                                                                                                                    |
| Resumen de la noticia | En septiembre de 2023, el grupo ALPHV/BlackCat atacó los sistemas de MGM Resorts mediante ingeniería social. Se hicieron pasar por un empleado ante el servicio de soporte técnico para obtener acceso al sistema. Las máquinas tragaperras, los sistemas de check-in, las reservas de restaurantes y los ascensores estuvieron inoperativos durante días. |
| Riesgos asociados     | <ul style="list-style-type: none"><li>• Ingeniería social contra el helpdesk de TI (vishing)</li><li>• Ausencia de verificación de identidad robusta en solicitudes de soporte</li><li>• Sistemas críticos de OT (ascensores, accesos) conectados a la misma red que IT</li></ul>                                                                          |
| Propuestas            | <ul style="list-style-type: none"><li>• Protocolos estrictos de verificación de identidad para soporte técnico</li><li>• Separación física y lógica de redes IT y OT</li><li>• Formación específica anti-ingeniería social para el equipo de helpdesk</li></ul>                                                                                            |

### Caso 3:

|                       |                                                                                                                                                                                                                                                                                                                                      |
|-----------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Titular               | Ataque a cadena hotelera europea mediante cerraduras IoT: acceso a habitaciones (2022)                                                                                                                                                                                                                                               |
| Enlace                | <a href="https://www.wired.com/story/hotel-lock-vulnerabilities/">https://www.wired.com/story/hotel-lock-vulnerabilities/</a>                                                                                                                                                                                                        |
| Resumen de la noticia | Investigadores de seguridad demostraron que las cerraduras electrónicas de una popular cadena hotelera europea eran vulnerables a ataques de fuerza bruta sobre el protocolo RFID. Con un dispositivo de bajo coste, era posible clonar tarjetas llave y acceder a cualquier habitación del hotel sin dejar rastro en los registros. |
| Riesgos asociados     | <ul style="list-style-type: none"><li>• Protocolo RFID obsoleto sin cifrado actualizado en cerraduras electrónicas</li><li>• Falta de auditorías de seguridad en dispositivos IoT de OT</li><li>• No se registraban logs de accesos físicos para detección de anomalías</li></ul>                                                    |
| Propuestas            | <ul style="list-style-type: none"><li>• Actualización a estándares RFID modernos con cifrado robusto (MIFARE DESFire)</li><li>• Registro y monitorización de todos los accesos físicos con alertas automáticas</li><li>• Auditorías de penetración periódicas sobre la infraestructura IoT</li></ul>                                 |

## 4. Propuesta de Estrategia de Ciberseguridad para +hotel

### 4.1. Jerarquía de accesos y control de identidades

Siguiendo el principio de mínimo privilegio, se propone estructurar el acceso a los sistemas en tres niveles diferenciados:

- Nivel Operativo (Recepción/Restauración): Acceso exclusivo al PMS para check-in/out, consulta de reservas y TPV. Sin acceso a datos financieros históricos ni a otros sistemas.
- Nivel Gestión (Directores de área): Acceso a informes de su área, gestión de personal y proveedores. Sin acceso a configuraciones de sistemas.
- Nivel Administración Central (TI / Dirección): Acceso completo para auditorías, configuración y visión global de todos los sistemas.

Para todos los niveles se activará autenticación multifactor (MFA) obligatoria: contraseña corporativa más código temporal en dispositivo móvil de empresa.

### 4.2. Segmentación de red y protección de infraestructura

Se propone dividir la infraestructura de red en zonas aisladas mediante VLANs, de forma que un compromiso en una zona no se propague a las demás:

- Red Corporativa IT: PMS, correo, gestión financiera y reservas.
- Red IoT/OT: Cerraduras, climatización, televisores y sensores. Completamente aislada de la red corporativa.
- Red de Huéspedes (Wi-Fi): Acceso a internet para clientes, sin ningún acceso a redes internas.
- Red de Gestión: Acceso exclusivo para administradores de TI a la infraestructura.

Las comunicaciones entre tiendas y la sede central irán cifradas mediante VPN de nivel empresarial, garantizando que los datos no viajen en texto plano por internet.

### 4.3. Continuidad de negocio y respuesta a incidentes

Ante la experiencia de +hotel con la parálisis de sistemas durante días, es imprescindible disponer de un Plan de Continuidad de Negocio (BCP) que contemple:

- Copias de seguridad offline automáticas cada 24 horas, almacenadas en ubicación físicamente separada y desconectada de la red principal (air-gap).
- Procedimiento documentado de recuperación ante desastres (DRP) con tiempos de recuperación definidos (RTO < 4 horas para sistemas críticos).
- Sistemas de detección y respuesta a incidentes (EDR/SIEM) que alerten de comportamientos anómalos en tiempo real.
- Simulacros de ciberataque (Red Team) semestrales para verificar la efectividad de los controles.

#### 4.4. Formación y cultura de seguridad

El factor humano sigue siendo el vector de ataque más explotado. Se propone implementar un programa de concienciación continua:

- Formación obligatoria trimestral para todo el personal en detección de phishing, ingeniería social y gestión segura de contraseñas.
- Simulacros de phishing periódicos para medir la tasa de clics y reforzar la formación donde sea necesario.
- Canal confidencial de reporte de incidentes para que cualquier empleado pueda notificar una sospecha sin temor a represalias.

## 5. Presentación de Resultados y Conclusiones Finales

Para cerrar el informe, respondemos a las cuestiones planteadas sobre el panorama actual de ciberseguridad en el sector turístico:

### **¿Cuáles han sido las mayores dificultades para identificar y analizar los riesgos?**

La principal dificultad ha sido la convergencia de IT y OT en el entorno hotelero. Mientras los riesgos de las tecnologías de la información son bien conocidos, los riesgos de los dispositivos físicos conectados (cerraduras, climatización) son menos intuitivos y, paradójicamente, más peligrosos porque afectan a la seguridad física de los huéspedes. Además, muchas cadenas hoteleras no documentan públicamente sus brechas por miedo al impacto reputacional, lo que dificulta el análisis de casos reales.

### **¿Qué medidas adicionales serían necesarias a largo plazo?**

A largo plazo, la ciberseguridad hotelera necesita evolucionar en tres frentes: primero, el cumplimiento normativo activo con el RGPD y el Esquema Nacional de Seguridad, no solo como obligación legal sino como ventaja competitiva de confianza para el cliente. Segundo, la integración de inteligencia artificial en los sistemas SIEM para detectar patrones de ataque antes de que se materialicen. Tercero, la colaboración sectorial mediante grupos de intercambio de información sobre amenazas (ISACs) específicos para el turismo, de forma similar a los que ya existen en banca o infraestructuras críticas.

### **¿Diferencias con otras propuestas?**

Nuestra propuesta se diferencia en que no se limita a instalar herramientas técnicas, sino que plantea un cambio cultural en la organización. La tecnología sin formación es un escudo con agujeros: de nada sirve el mejor firewall si un recepcionista entrega sus credenciales por teléfono a alguien que dice ser del soporte técnico. Hemos puesto el foco en que +hotel entienda que la ciberseguridad no es un gasto, sino una inversión directa en la confianza del cliente y en la continuidad del negocio.